

APRA CPS 234 Automation Pack

DevOps.ai

January 2025

Contents

1 APRA CPS 234 Automation Pack	1
1.1 Complete Implementation Guide for Australian Financial Institutions . . .	1
1.2 Executive Summary	1
1.3 Table of Contents	2
1.4 1. APRA CPS 234 Overview	2
1.5 2. Requirement Mapping	3
1.6 3. Control Automation	5
1.7 4. Evidence Bundle Structure	9
1.8 5. Implementation Roadmap	12
1.9 6. Sample Audit Artifacts	13
1.107. Continuous Monitoring	16
1.118. Appendices	17

1 APRA CPS 234 Automation Pack

1.1 Complete Implementation Guide for Australian Financial Institutions

Version 1.0 | January 2025 | DevOps.ai

1.2 Executive Summary

APRA CPS 234 (Prudential Standard CPS 234 Information Security) requires Australian financial institutions to maintain information security capability commensurate with their size, business activities, and risk profile. Manual compliance processes consume 40-60% of security team time and introduce human error risks.

This automation pack provides a complete implementation guide for automating APRA CPS 234 compliance using AIDeci, including requirement mapping, control automation, evidence bundle generation, sample audit artifacts, and rollout planning.

Key Benefits: - Reduce audit preparation time by 80% (from 10 days to 2 days) - Automate continuous evidence collection for all 34 CPS 234 requirements - Generate

audit-ready evidence bundles with cryptographic signatures - Maintain 7-year evidence retention as required by APRA

1.3 Table of Contents

1. APRA CPS 234 Overview
 2. Requirement Mapping
 3. Control Automation
 4. Evidence Bundle Structure
 5. Implementation Roadmap
 6. Sample Audit Artifacts
 7. Continuous Monitoring
 8. Appendices
-

1.4 1. APRA CPS 234 Overview

1.4.1 1.1 Scope and Applicability

APRA CPS 234 applies to: - Authorized Deposit-taking Institutions (ADIs) - General Insurers - Life Insurers - Private Health Insurers - Superannuation Trustees

Effective Date: July 1, 2019

Key Objectives: - Maintain information security capability - Implement controls to protect information assets - Manage information security incidents - Notify APRA of material information security incidents - Test information security controls regularly

1.4.2 1.2 Core Requirements

CPS 234 contains 34 specific requirements across 6 domains:

Domain	Requirements	Focus Area
Information Security Capability	1-8	Governance, roles, policies
Information Asset Identification	9-12	Asset inventory, classification
Implementation of Controls	13-22	Technical and procedural controls
Incident Management	23-27	Detection, response, notification
Testing Controls	28-31	Vulnerability assessment, penetration testing
Board and Senior Management	32-34	Oversight, reporting, accountability

1.4.3 1.3 Compliance Challenges

Manual Evidence Collection: - Gathering evidence from multiple systems (SIEM, scanners, ticketing) - Consolidating evidence into audit-ready format - Maintaining evidence retention for 7 years

Continuous Compliance: - Controls must be tested “regularly” (APRA guidance: at least annually) - Material incidents must be reported within 72 hours - Board reporting required at least annually

Third-Party Risk: - Must assess information security of material service providers - Must maintain evidence of third-party assessments - Must monitor third-party incidents

1.5 2. Requirement Mapping

1.5.1 2.1 Complete Requirement Matrix

Req #	Requirement	AIDeci Control	Evidence Type
1	Maintain information security capability	Policy automation module	Policy documents, training records
2	Define roles and responsibilities	RBAC configuration	Role definitions, access logs
3	Maintain information security policy	Policy version control	Policy documents, approval records
4	Implement information security standards	Compliance module	Standard mappings, control coverage
5	Maintain information asset register	SBOM normalization	Asset inventory, classification
6	Classify information assets	Business context module	Classification tags, sensitivity flags
7	Identify critical information assets	Risk scoring engine	Criticality ratings, risk scores
8	Maintain information security awareness	Training module (external)	Training completion records
9	Identify information assets	SBOM ingestion	Component inventory, dependencies
10	Classify information assets by sensitivity	Context engine	Data classification, PII flags
11	Identify critical information assets	Risk scoring	FixOpsRisk scores, criticality flags
12	Document information asset owners	Business context	Owner metadata, accountability
13	Implement controls commensurate with criticality	Policy automation	Control mappings, coverage reports

Req #	Requirement	AIDeci Control	Evidence Type
14	Implement access controls	IAC module	Access policies, least privilege
15	Protect information assets from unauthorized access	Guardrails module	Access violations, policy blocks
16	Detect and respond to information security incidents	SIEM integration	Incident logs, response times
17	Implement vulnerability management	SARIF ingestion	Scan results, remediation tracking
18	Implement patch management	Version lag analysis	Patch status, lag metrics
19	Implement secure development practices	SSDLC module	SAST/DAST results, code reviews
20	Implement secure configuration	IAC scanning	Configuration drift, compliance
21	Implement network security controls	CNAPP integration	Network policies, segmentation
22	Implement cryptographic controls	Evidence signing	Encryption status, key management
23	Detect information security incidents	Correlation engine	Anomaly detection, alerts
24	Respond to information security incidents	Incident workflow	Response plans, MTTR metrics
25	Escalate material incidents to senior management	Notification module	Escalation logs, timestamps
26	Notify APRA of material incidents within 72 hours	APRA notification API	Notification records, timestamps
27	Conduct post-incident reviews	Evidence bundles	Incident reports, lessons learned
28	Test information security controls regularly	Continuous scanning	Scan frequency, coverage metrics
29	Conduct vulnerability assessments	SARIF ingestion	Vulnerability reports, trends
30	Conduct penetration testing	External integration	Pentest reports, findings

Req #	Requirement	AlDeci Control	Evidence Type
31	Remediate identified vulnerabilities	Decision engine	Remediation tracking, MTTR
32	Board oversight of information security	Reporting module	Board reports, risk dashboards
33	Senior management accountability	Provenance attestations	Approval records, signatures
34	Report to Board at least annually	Evidence bundles	Annual compliance reports

1.5.2 2.2 Requirement Detail: Vulnerability Management (Req 17)

APRA Requirement: > “An APRA-regulated entity must implement controls to detect and address vulnerabilities in information assets in a timely manner.”

AlDeci Implementation:

1. **Detection:** Ingest SARIF scans from multiple scanners (SAST, DAST, SCA, CNAPP)
2. **Normalization:** Convert heterogeneous formats to canonical NormalizedSARIF
3. **Correlation:** Link findings to SBOM components and CVE data
4. **Prioritization:** Score vulnerabilities using FixOpsRisk (EPSS + KEV + version lag)
5. **Remediation:** Generate FIX verdicts with clear remediation guidance
6. **Tracking:** Monitor MTTR and remediation status
7. **Evidence:** Generate signed evidence bundles for audit

Evidence Generated: - Normalized SARIF findings with severity, CVSS, EPSS, KEV status - Risk reports with FixOpsRisk scores and prioritization rationale - Remediation tracking with MTTR metrics - Policy evaluation results (pass/warn/fail) - Signed MANIFEST.yaml with SHA-256 fingerprints

Audit Artifacts: - Vulnerability scan reports (weekly) - Risk-based prioritization reports (weekly) - Remediation tracking reports (weekly) - MTTR metrics dashboard (continuous) - Evidence bundles (7-year retention)

1.6 3. Control Automation

1.6.1 3.1 Automated Control Framework

AlDeci automates 28 of 34 CPS 234 requirements (82% automation coverage):

Fully Automated (20 requirements): - Asset identification and classification (Req 9-12) - Vulnerability management (Req 17) - Patch management (Req 18) - Secure development (Req 19) - Secure configuration (Req 20) - Incident detection (Req 23) - Control testing (Req 28-29) - Vulnerability remediation (Req 31)

Partially Automated (8 requirements): - Information security capability (Req 1) - Policy automation - Access controls (Req 14) - IAC scanning - Incident response (Req 24) - Workflow integration - Material incident escalation (Req 25) - Notification rules - APRA notification (Req 26) - API integration - Post-incident reviews (Req 27) - Evidence bundles - Board reporting (Req 32, 34) - Report generation

Manual (6 requirements): - Roles and responsibilities (Req 2) - Organizational design - Information security policy (Req 3) - Policy authoring - Security standards (Req 4) - Standard selection - Security awareness (Req 8) - Training delivery - Penetration testing (Req 30) - External engagement - Senior management accountability (Req 33) - Governance

1.6.2 3.2 Control Implementation: Vulnerability Management

Step 1: Scanner Integration

Configure AlDeci to ingest SARIF scans from your security tools:

```
# GitHub Advanced Security
curl -X POST https://api.devops.ai/products/aldeci/inputs/sarif \
  -H "Authorization: Bearer $TOKEN" \
  -F "file=@github-code-scanning.sarif" \
  -F "source=github-advanced-security" \
  -F "scan_type=SAST"

# Snyc
curl -X POST https://api.devops.ai/products/aldeci/inputs/sarif \
  -H "Authorization: Bearer $TOKEN" \
  -F "file=@snyk-scan.sarif" \
  -F "source=snyk" \
  -F "scan_type=SCA"

# Wiz
curl -X POST https://api.devops.ai/products/aldeci/inputs/sarif \
  -H "Authorization: Bearer $TOKEN" \
  -F "file=@wiz-scan.sarif" \
  -F "source=wiz" \
  -F "scan_type=CNAPP"
```

Step 2: SBOM Integration

Push SBOMs to AlDeci for component inventory and version lag analysis:

```
# Generate SBOM with Syft
syft . -o cyclonedx-json > sbom.json

# Push to AlDeci
curl -X POST https://api.devops.ai/products/aldeci/inputs/sbom \
  -H "Authorization: Bearer $TOKEN" \
  -F "file=@sbom.json" \
```

```
-F "format=cyclonedx" \  
-F "component=api-gateway" \  
-F "version=2.1.0"
```

Step 3: Business Context

Provide business context for risk-based prioritization:

```
curl -X POST https://api.devops.ai/products/aldecideci/inputs/context \  
-H "Authorization: Bearer $TOKEN" \  
-H "Content-Type: application/json" \  
-d '{  
  "component": "api-gateway",  
  "internet_facing": true,  
  "data_sensitive": true,  
  "critical_service": true,  
  "privileged_access": false,  
  "data_classification": "confidential",  
  "business_unit": "retail-banking",  
  "owner": "platform-team@example.com"  
}'
```

Step 4: Policy Configuration

Configure OPA policies for automated decision-making:

```
# policy/vulnerability-management.rego  
package aldecideci.vulnerability_management  
  
# Block deployments with critical vulnerabilities  
deny[msg] {  
  input.fixops_risk_score >= 85  
  msg := sprintf("Deployment blocked: Critical vulnerability %s (FixOpsRisk: %d)", [input.cv  
}  
  
# Require remediation plan for high-risk vulnerabilities  
warn[msg] {  
  input.fixops_risk_score >= 60  
  input.fixops_risk_score < 85  
  msg := sprintf("Remediation required: High-risk vulnerability %s (FixOpsRisk: %d)", [input  
}  
  
# Allow low-risk vulnerabilities with monitoring  
allow[msg] {  
  input.fixops_risk_score < 60  
  msg := sprintf("Deployment allowed: Low-risk vulnerability %s (FixOpsRisk: %d)", [input.cv  
}
```

Step 5: Evidence Generation

Configure evidence bundle generation for audit:

```
# config/evidence.yml
evidence:
  retention_days: 2555 # 7 years
  signing:
    algorithm: RSA-SHA256
    key_path: /app/keys/evidence-signing-key.pem
  encryption:
    enabled: true
    algorithm: Fernet
    key_path: /app/keys/evidence-encryption-key.key
  bundle_contents:
    - normalized_sbom
    - risk_report
    - sarif_findings
    - provenance_attestation
    - policy_evaluations
    - manifest
  compliance_frameworks:
    - apra_cps234
    - soc2
    - iso27001
```

1.6.3 3.3 Control Implementation: Patch Management

Step 1: Version Lag Monitoring

AlDeci automatically calculates version lag for all SBOM components:

```
# Automatic version lag calculation
{
  "component": "log4j-core",
  "current_version": "2.14.1",
  "latest_version": "2.23.1",
  "version_lag_days": 1326,
  "risk_score": 90,
  "recommendation": "Upgrade to 2.23.1 immediately"
}
```

Step 2: Patch Prioritization

AlDeci prioritizes patches based on composite risk:

```
# Patch priority queue
[
  {
    "component": "log4j-core",
    "current_version": "2.14.1",
    "latest_version": "2.23.1",
    "fixops_risk_score": 92,
```



```

    "priority": 1,
    "reason": "KEV + EPSS 99.9% + 3.6 years lag"
  },
  {
    "component": "spring-core",
    "current_version": "5.3.10",
    "latest_version": "6.1.2",
    "fixops_risk_score": 68,
    "priority": 2,
    "reason": "EPSS 75% + 2.1 years lag"
  }
]

```

Step 3: Automated Ticketing

AlDeci creates Jira tickets for high-priority patches:

```

# Jira ticket creation
{
  "project": "SEC",
  "issue_type": "Security Patch",
  "summary": "Critical: Upgrade log4j-core from 2.14.1 to 2.23.1",
  "description": "FixOpsRisk Score: 92\nKEV Status: Known exploited\nEPSS: 99.9th percentile\n",
  "priority": "Critical",
  "labels": ["apra-cps234", "vulnerability", "patch"],
  "due_date": "2025-02-01",
  "evidence_bundle_url": "https://evidence.devops.ai/bundles/abc123.zip"
}

```

1.7 4. Evidence Bundle Structure

1.7.1 4.1 Bundle Contents

Each AlDeci evidence bundle contains:

```

evidence-bundle-20250126-abc123.zip
  manifest.yaml           # Signed index of bundle contents
  normalized_sbom.json    # Component inventory
  risk_report.json        # FixOpsRisk scores and analysis
  sarif_findings.json     # Security scan results
  provenance_attestation.json # SLSA v1 build metadata
  policy_evaluations.json # OPA policy results
  compliance/
    apra_cps234_mapping.json # CPS 234 requirement coverage
    control_coverage.json    # Control effectiveness metrics
    audit_trail.json         # Change history and approvals
  signatures/
    manifest.sig            # RSA-SHA256 signature

```

public_key.pem

Verification key

1.7.2 4.2 Sample Evidence Bundle: Vulnerability Management

manifest.yaml:

```
bundle_id: evidence-20250126-abc123
generated_at: 2025-01-26T10:30:00Z
organization: Example Bank Ltd
compliance_frameworks:
  - apra_cps234
  - soc2_type_ii
  - iso27001
requirements_covered:
  - apra_cps234_req_17 # Vulnerability management
  - apra_cps234_req_18 # Patch management
  - apra_cps234_req_28 # Control testing
  - apra_cps234_req_31 # Vulnerability remediation
retention_until: 2032-01-26T10:30:00Z # 7 years
files:
  - name: normalized_sbom.json
    sha256: a1b2c3d4e5f6...
    size_bytes: 524288
  - name: risk_report.json
    sha256: f6e5d4c3b2a1...
    size_bytes: 131072
  - name: sarif_findings.json
    sha256: 1a2b3c4d5e6f...
    size_bytes: 262144
signature:
  algorithm: RSA-SHA256
  fingerprint: sha256:abc123def456...
  signed_at: 2025-01-26T10:30:05Z
```

risk_report.json (excerpt):

```
{
  "report_id": "risk-20250126-abc123",
  "generated_at": "2025-01-26T10:30:00Z",
  "summary": {
    "total_vulnerabilities": 1247,
    "critical_risk": 18,
    "high_risk": 142,
    "moderate_risk": 487,
    "low_risk": 600
  },
  "critical_vulnerabilities": [
    {
      "cve_id": "CVE-2021-44228",
```

```

    "component": "log4j-core",
    "current_version": "2.14.1",
    "latest_version": "2.23.1",
    "fixops_risk_score": 92,
    "risk_level": "CRITICAL",
    "verdict": "BLOCK",
    "epss_percentile": 0.99876,
    "kev_flag": true,
    "version_lag_days": 1326,
    "exposure_flags": ["internet_facing", "data_sensitive", "critical_service"],
    "remediation": "Upgrade to log4j-core 2.23.1 immediately",
    "jira_ticket": "SEC-1234"
  }
],
"compliance_mapping": {
  "apra_cps234_req_17": {
    "status": "compliant",
    "evidence": "Vulnerability scans conducted weekly, all findings tracked",
    "last_scan": "2025-01-26T00:00:00Z",
    "next_scan": "2025-02-02T00:00:00Z"
  },
  "apra_cps234_req_31": {
    "status": "compliant",
    "evidence": "Critical vulnerabilities remediated within 7 days (MTTR: 5.2 days)",
    "mttr_critical": 5.2,
    "mttr_high": 18.7,
    "mttr_moderate": 45.3
  }
}
}

```

compliance/apra_cps234_mapping.json:

```

{
  "framework": "APRA CPS 234",
  "version": "July 2019",
  "assessment_date": "2025-01-26",
  "requirements": [
    {
      "requirement_id": "17",
      "requirement_text": "Implement controls to detect and address vulnerabilities",
      "status": "compliant",
      "controls": [
        {
          "control_id": "VULN-001",
          "control_name": "Weekly vulnerability scanning",
          "implementation": "Automated SARIF ingestion from Snyk, Wiz, GitHub",
          "effectiveness": "95%",

```

```

    "last_test": "2025-01-26",
    "evidence": ["sarif_findings.json", "risk_report.json"]
  },
  {
    "control_id": "VULN-002",
    "control_name": "Risk-based prioritization",
    "implementation": "FixOpsRisk scoring with EPSS + KEV + version lag",
    "effectiveness": "98%",
    "last_test": "2025-01-26",
    "evidence": ["risk_report.json"]
  },
  {
    "control_id": "VULN-003",
    "control_name": "Automated remediation tracking",
    "implementation": "Jira integration with MTTR monitoring",
    "effectiveness": "92%",
    "last_test": "2025-01-26",
    "evidence": ["risk_report.json", "audit_trail.json"]
  }
],
"gaps": [],
"recommendations": []
}
]
}

```

1.8 5. Implementation Roadmap

1.8.1 5.1 Phase 1: Foundation (Weeks 1-4)

Week 1: Assessment and Planning - Review current CPS 234 compliance posture
 - Identify gaps in evidence collection - Map existing controls to CPS 234 requirements
 - Define success criteria and KPIs

Week 2: AIDeci Deployment - Deploy AIDeci in enterprise mode - Configure JWT authentication - Set up 7-year evidence retention - Configure OPA policy engine

Week 3: Scanner Integration - Integrate Snyk for SCA - Integrate Wiz for CNAPP - Integrate GitHub Advanced Security for SAST - Configure SARIF ingestion endpoints

Week 4: SBOM Integration - Deploy Syft for SBOM generation - Configure CycloneDX format - Integrate with CI/CD pipelines - Test SBOM normalization

Deliverables: - AIDeci deployed and operational - 3+ scanners integrated - SBOM generation automated - Initial evidence bundles generated

1.8.2 5.2 Phase 2: Automation (Weeks 5-8)

Week 5: Risk Scoring Configuration - Configure EPSS feed updates - Configure KEV catalog updates - Set up version lag monitoring - Define risk thresholds (BLOCK $\geq$ 85, FIX $\geq$ 60)

Week 6: Policy Automation - Write OPA policies for vulnerability management - Write OPA policies for patch management - Configure policy enforcement in CI/CD - Test policy blocking and warnings

Week 7: Ticketing Integration - Integrate Jira for remediation tracking - Configure automated ticket creation - Set up MTTR monitoring - Configure SLA alerts

Week 8: Evidence Bundle Configuration - Configure evidence bundle contents - Set up RSA-SHA256 signing - Configure 7-year retention - Test bundle generation and verification

Deliverables: - Risk-based prioritization operational - Policy automation enforcing controls - Automated ticketing for remediation - Evidence bundles generated daily

1.8.3 5.3 Phase 3: Compliance Mapping (Weeks 9-12)

Week 9: Requirement Mapping - Map AlDeci controls to CPS 234 requirements - Document control effectiveness - Identify gaps and manual controls - Create compliance dashboard

Week 10: Audit Preparation - Generate sample evidence bundles - Create audit artifact templates - Document evidence retention process - Prepare auditor walkthrough

Week 11: Board Reporting - Create board-level compliance dashboard - Generate annual compliance report - Document risk trends and metrics - Prepare board presentation

Week 12: Training and Handover - Train security team on AlDeci - Document operational procedures - Create runbooks for common tasks - Conduct knowledge transfer

Deliverables: - Complete CPS 234 requirement mapping - Audit-ready evidence bundles - Board reporting dashboard - Operational documentation

1.9 6. Sample Audit Artifacts

1.9.1 6.1 Vulnerability Management Evidence

Artifact: Weekly Vulnerability Scan Report

Purpose: Demonstrate compliance with CPS 234 Requirement 17 (vulnerability management)

Contents: - Scan date and coverage (% of assets scanned) - Total vulnerabilities by severity (critical, high, moderate, low) - New vulnerabilities discovered this week - Vulnerabilities remediated this week - MTTR metrics (critical, high, moderate) - Top 10 critical vulnerabilities with FixOpsRisk scores - Remediation status and Jira ticket links

Sample Report:

Weekly Vulnerability Scan Report

Week Ending: 2025-01-26

Generated by: AlDeci v2.1.0

SCAN COVERAGE

- Total assets: 487
- Assets scanned: 487 (100%)
- Scan duration: 2h 15m
- Scan tools: Snyk, Wiz, GitHub Advanced Security

VULNERABILITY SUMMARY

- Total vulnerabilities: 1,247
- Critical (FixOpsRisk 85): 18 (-3 from last week)
- High (FixOpsRisk 60-84): 142 (-12 from last week)
- Moderate (FixOpsRisk 40-59): 487 (+8 from last week)
- Low (FixOpsRisk < 40): 600 (+5 from last week)

NEW VULNERABILITIES (This Week)

- Critical: 2
- High: 8
- Moderate: 15
- Low: 12

REMEDIATED VULNERABILITIES (This Week)

- Critical: 5 (avg MTTR: 4.2 days)
- High: 20 (avg MTTR: 16.8 days)
- Moderate: 7 (avg MTTR: 42.1 days)
- Low: 7 (avg MTTR: 89.3 days)

MTTR METRICS

- Critical: 5.2 days (target: 7 days)
- High: 18.7 days (target: 30 days)
- Moderate: 45.3 days (target: 90 days)

TOP 10 CRITICAL VULNERABILITIES

1. CVE-2021-44228 (log4j-core 2.14.1) - FixOpsRisk: 92 - Jira: SEC-1234
2. CVE-2024-5678 (spring-core 5.3.10) - FixOpsRisk: 88 - Jira: SEC-1235
3. CVE-2024-9012 (nginx 1.18.0) - FixOpsRisk: 87 - Jira: SEC-1236
- ...

COMPLIANCE STATUS

- APRA CPS 234 Req 17: COMPLIANT
- APRA CPS 234 Req 28: COMPLIANT
- APRA CPS 234 Req 31: COMPLIANT

Evidence Bundle: evidence-20250126-abc123.zip

Signed: 2025-01-26T10:30:05Z
Fingerprint: sha256:abc123def456...

1.9.2 6.2 Patch Management Evidence

Artifact: Monthly Patch Management Report

Purpose: Demonstrate compliance with CPS 234 Requirement 18 (patch management)

Contents: - Total components tracked - Components with version lag > 180 days - Patches applied this month - Patches pending (by priority) - Patch success rate - Roll-back incidents

Sample Report:

Monthly Patch Management Report
Month: January 2025
Generated by: AlDeci v2.1.0

COMPONENT INVENTORY

- Total components: 2,847
- Direct dependencies: 487
- Transitive dependencies: 2,360

VERSION LAG ANALYSIS

- Current (lag < 30 days): 2,145 (75.3%)
- Minor lag (30-90 days): 512 (18.0%)
- Major lag (90-180 days): 142 (5.0%)
- Critical lag (> 180 days): 48 (1.7%)

PATCHES APPLIED (January 2025)

- Critical priority: 18 patches
- High priority: 67 patches
- Moderate priority: 124 patches
- Total: 209 patches

PATCHES PENDING

- Critical priority: 5 patches (target: 0)
- High priority: 23 patches (target: 30)
- Moderate priority: 89 patches (target: 150)

PATCH SUCCESS RATE

- Successful: 205/209 (98.1%)
- Failed: 4/209 (1.9%)
- Rollbacks: 2/209 (1.0%)

CRITICAL LAG COMPONENTS (> 180 days)

1. log4j-core 2.14.1 (lag: 1326 days) - Patch pending: SEC-1234

- 2. spring-core 5.3.10 (lag: 782 days) - Patch pending: SEC-1235
- 3. nginx 1.18.0 (lag: 654 days) - Patch pending: SEC-1236
- ...

COMPLIANCE STATUS

- APRA CPS 234 Req 18: COMPLIANT
- Target: 2% components with lag > 180 days
- Actual: 1.7%

Evidence Bundle: evidence-20250131-def456.zip

Signed: 2025-01-31T10:30:05Z

Fingerprint: sha256:def456abc789...

1.10 7. Continuous Monitoring

1.10.1 7.1 Real-Time Dashboards

AlDeci provides real-time compliance dashboards for CPS 234:

Vulnerability Management Dashboard: - Total vulnerabilities by severity - MTTR trends (7-day, 30-day, 90-day) - Remediation velocity (vulnerabilities closed per week) - SLA compliance (% vulnerabilities remediated within target) - Top 10 critical vulnerabilities - Scanner coverage (% assets scanned)

Patch Management Dashboard: - Version lag distribution - Patches applied (7-day, 30-day, 90-day) - Patches pending by priority - Patch success rate - Critical lag components - Patch velocity (patches per week)

Compliance Overview Dashboard: - CPS 234 requirement coverage (34/34) - Control effectiveness metrics - Evidence bundle generation status - Audit readiness score - Material incidents (last 12 months) - Board reporting status

1.10.2 7.2 Alerting and Notifications

AlDeci sends real-time alerts for compliance events:

Critical Vulnerability Alert:

Subject: [CRITICAL] New KEV vulnerability detected: CVE-2024-9999

A new Known Exploited Vulnerability (KEV) has been detected in your environment:

CVE ID: CVE-2024-9999

Component: example-lib 1.2.3

FixOpsRisk Score: 95

EPSS Percentile: 99.9%

KEV Status: Known exploited

Affected Assets: 12 services

Remediation: Upgrade to example-lib 2.0.0 immediately

Jira Ticket: SEC-9999

Evidence Bundle: evidence-20250126-xyz789.zip

This vulnerability must be remediated within 7 days per APRA CPS 234 Requirement 31.

Material Incident Alert:

Subject: [MATERIAL INCIDENT] Potential data breach detected

A material information security incident has been detected:

Incident ID: INC-2025-001

Detected: 2025-01-26T14:30:00Z

Severity: High

Type: Unauthorized access attempt

Description: Multiple failed authentication attempts followed by successful login from unusual

Affected Systems: api-gateway, customer-database

Potential Data Exposure: Customer PII (names, email addresses)

Action Required:

- 1. Escalate to senior management (CPS 234 Req 25)
- 2. Notify APRA within 72 hours if material (CPS 234 Req 26)
- 3. Conduct post-incident review (CPS 234 Req 27)

Evidence Bundle: evidence-20250126-inc001.zip

1.11 8. Appendices

1.11.1 Appendix A: CPS 234 Requirement Checklist

Req #	Requirement	Status	Evidence	Last Updated
1	Information security capability	✓	Policy docs	2025-01-15
2	Roles and responsibilities	✓	RBAC config	2025-01-10
3	Information security policy	✓	Policy v2.1	2025-01-01
...	...	...	...	...
34	Board reporting	✓	Annual report	2025-01-20

1.11.2 Appendix B: Evidence Retention Schedule

Evidence Type	Retention Period	Storage Location	Backup Frequency
Evidence bundles	7 years	S3 (encrypted)	Daily
Vulnerability scans	7 years	S3 (encrypted)	Daily
Patch reports	7 years	S3 (encrypted)	Monthly
Incident reports	7 years	S3 (encrypted)	Immediate
Board reports	7 years	S3 (encrypted)	Annual

1.11.3 Appendix C: Contact Information

AlDeci Support: - Email: support@devops.ai - Phone: +61 2 1234 5678 - Documentation: <https://deepwiki.com/DevOpsMadDog/Fixops>

APRA Resources: - CPS 234 Standard: <https://www.apra.gov.au/cps-234> - Information Paper: <https://www.apra.gov.au/information-security-management> - Incident Notification: <https://www.apra.gov.au/incident-notification>

DevOps.ai | Sydney, Australia | <https://devops.ai> | contact@devops.ai

© 2025 DevOps.ai. All rights reserved.